GLOBALTECH INC.
Quantitative Phishing Risk Assessment

Executive briefing and calculation report | 30 October 2026

To: Board of Directors, CISO and CFO
From: GRC Risk Analysis Team
Subject: Phishing simulation results, scenario-based financial exposure and control priorities

1. Executive summary

The three simulations recorded 105 credential submissions from 430 emails sent, giving a pooled credential submission rate of 24.42%. Campaign B (IT System Password Reset) had the highest credential submission rate at 30.0%, followed by Campaign A at 18.0% and Campaign C at 15.0%. Campaign B is the highest immediate remediation priority.

Applying Campaign B's 30% credential rate to all 2,000 employees projects 600 credential submissions. Applying the supplied 25% conditional probability independently to each credential produces 150 expected breach events and $652.5 million in scenario expected loss. This is not validated ALE: annual event frequency, incident aggregation, and loss severity are not established.

Treat $652.5m as a simplified stress scenario, not a forecast or confirmed annual exposure. Prioritise MFA, targeted awareness and email controls, but validate effectiveness and overlapping benefits before presenting ROI as a forecast.

2. Phase 1 — campaign metrics

Basic rates use emails sent as the denominator. Conversion rates use the preceding attack stage.

Metric	Campaign A	Campaign B	Campaign C	Definition
Email open rate	82.0%	80.0%	90.0%	Opens/sent
Click-through rate	47.0%	60.0%	75.0%	Clicks / sent
Credential submission rate	18.0%	30.0%	15.0%	Credentials / sent
Data entry rate	5.0%	10.0%	10.0%	Data entries / sent
Open-to-click conversion	57.3%	75.0%	83.3%	Clicks / opens
Post-click credential conversion	38.3%	50.0%	20.0%	Credentials/clicks
Post-click data-entry conversion	10.6%	16.7%	13.3%	Data entries/clicks

Campaign C generated the highest click-through rate (75%) and open-to-click conversion (83.3%), but Campaign B generated the highest credential submission rate (30%) and post-click credential conversion (50%). Click rate must not be substituted for credential theft rate.

3. Phase 2 — risk quantification

3.1 Campaign B scaling scenario

- Credential submission rate = 75 / 250 = 30%.
- Projected credential submissions = 2,000 × 30% = 600.
- Expected breach events under the simplifying assumption = 600 × 25% = 150.
- Scenario expected loss = 150 × $4,350,000 = $652,500,000.

The arithmetic reproduces the brief. However, 150 is an expected count only if each compromised credential independently creates a breach opportunity. It is not proof of 150 distinct incidents. Multiple accounts may be involved in one incident.

3.2 Corrected campaign-specific exposure

Campaign	Credential rate	Projected credentials	Expected events (25%)	Scenario loss
A	18.0%	360	90	$391,500,000
B	30.0%	600	150	$652,500,000
C	15.0%	300	75	$326,250,000

The brief's Campaign A figure of $156.6m and Campaign C figure of $104.4m do not follow its formula. Consistent calculations are A: 360 × 25% × $4.35m = $391.5m; C: 300 × 25% × $4.35m = $326.25m.

3.3 Pooled result and ALE limitation

Pooled credential rate = (18 + 75 + 12) / (100 + 250 + 80) = 105 / 430 = 24.42%. Applied to 2,000 employees, this projects 488.4 credential submissions, 122.1 expected breach events and approximately $531.1m scenario expected loss. This assumes the campaign groups are comparable and representative.

ALE = SLE × ARO, where ARO is annual frequency. The brief supplies a breach cost and conditional probability but no annual phishing/credential compromise frequency or validated count of distinct incidents. Therefore, $652.5m must be labelled scenario expected loss/exposure, not annual ALE.

4. Phase 3 — risk assessment matrix

Campaign	Relative risk	Scenario loss	Priority	Recommended action
A — HR Bonus	Medium-high	$391.5m	2	HR-themed simulations, reporting drills and coaching.
B — Password Reset	Critical / highest	$652.5m	1	MFA, password-reset verification and risky sign-in alerting.
C — CEO Document	High	$326.25m	2	Executive/assistant training and separate-channel verification.

Priority is relative to the simplified scenario model, not a formal likelihood-impact score. A full rating should also consider asset criticality, privileged access, threat intelligence, existing controls, detectability and incident aggregation.

5. Statistical analysis — 95% confidence intervals

Using the normal/Wald approximation $p \pm 1.96 \times \sqrt{[p(1-p)/n]}$:

Campaign	p	n	Margin of error	95% interval
A	18.0%	100	7.53 percentage points	10.47%–25.53%
B	30.0%	250	5.68 percentage points	24.32%–35.68%
C	15.0%	80	7.82 percentage points	7.18%–22.82%

Campaign A: p = 0.18, n = 100. MOE = 1.96 × √[(0.18 × 0.82) / 100] = 1.96 × √0.001476 = 0.0753 (7.53 percentage points). Interval = 18% ± 7.53% = 10.47% to 25.53%.

These approximate intervals assume independent binomial outcomes. The campaigns target different groups and use different lures, so they are not a controlled A/B test. The intervals do not correct for selection bias or non-representative targeting. Wilson intervals are preferable for formal reporting, especially with smaller samples.

6. Control cost-benefit analysis

6.1 MFA

Cost = $45 × 2,000 = $90,000. If the assumed 99.9% reduction applies to the full $652.5m scenario loss, gross modelled reduction = $652.5m × 99.9% = $651,847,500. Net benefit after upfront cost = $651,757,500. Simple ROI = (gross reduction − cost) / cost × 100 = 724,175%.

This ROI is mathematically consistent with the supplied assumptions but is not a reliable forecast. MFA does not eliminate all phishing risk; effectiveness depends on coverage, method, bypass resistance and adoption.

6.2 Security awareness training

Cost = $50 × 2,000 = $100,000. The brief says training reduces click-through rates by 60%. Applied to Campaign B's 60% click rate, the new click rate is 24%, not 12%. The brief's 12% result applies a 60% reduction to the 30% credential submission rate, which is a different assumption.

Illustrative sensitivity only: if training reduces the credential submission rate by 60%, the rate becomes 12%; projected submissions = 240; expected events = 60; scenario loss = $261m; gross reduction = $391.5m; net benefit after $100k = $391.4m; simple ROI = 391,400%. This is not directly proven by a click-rate reduction.

6.3 Email filtering and combined controls

The brief's $130.5m email-filtering risk reduction implies 20% of the $652.5m baseline, but no effectiveness evidence is supplied. The workbook treats 20% as illustrative only. Combined control

effects may overlap; the workbook uses a multiplicative illustration rather than simply adding percentages, but actual interaction must be measured.

The listed initiatives total $490,000: MFA $90k + targeted simulation $25k + awareness training $100k + email gateway $50k + monitoring $150k + behaviour analytics $75k. This excludes ongoing operations, maintenance, licensing, integration and staff time unless included in those estimates.

7. Executive recommendations

- Q1: Enforce MFA for workforce accounts, prioritising privileged users, remote access, email, VPN and administrative systems. Prefer phishing-resistant methods where feasible.
- Q1: Strengthen password reset and account recovery with trusted-channel verification, monitoring and alerts.
- Q1: Run targeted simulations for HR, IT support, executives and assistants. Measure credential submission and reporting rates, not clicks alone.
- Q1–Q2: Deploy or tune email gateway controls, domain authentication, URL protection and attachment analysis.
- Q2: Establish incident-level reporting that links multiple compromised accounts to one incident where appropriate; record event frequency and loss severity.
- Quarterly: Repeat comparable simulations, track trends and test whether control improvements are statistically and operationally meaningful.

8. Post-control targets and financial governance

A proposed 90% reduction in credential theft and ALE is a target assumption, not a demonstrated result. Applied to $652.5m, it gives residual scenario loss of $65.25m and gross reduction of $587.25m. Actual combined effectiveness cannot be derived from the supplied data.

Per-employee scenario exposure = $652.5m / 2,000 = $326,250. This is an average allocation, not a prediction of individual employee loss. The brief's 93.75% major-breach probability is unsupported. It equals 1 − 0.75^5, not a derivation from 150 expected events. If 600 independent credential thefts each had 25% event probability, the probability of at least one event would be 1 − 0.75^600, effectively 100%; independence and event definitions are not established.

9. Bonus — break-even

Break-even expected breaches = $490,000 / $4,350,000 = 0.1126 expected breaches. In whole-incident terms, preventing one breach at the assumed cost would exceed the investment. This assumes the full cost is avoidable and attributable to the controls, and excludes operating costs.

10. Assumptions and limitations

- Simulation sample sizes are 100, 250 and 80; they may not represent all 2,000 employees.
- The $4.35m breach cost and 25% conditional probability are scenario assumptions, not verified benchmarks.
- A credential submission is not the same as confirmed account compromise or a confirmed breach.

- Multiple compromised accounts may be aggregated into one incident; per-account incident modelling may overstate incident counts and loss.
- A quarter's simulation does not define annual occurrence frequency; a defensible ARO is required for ALE.
- The $85,000 salary input is contextual only and is not used in breach-loss calculations.
- Control effectiveness, coverage, recurring costs and overlap require validation through pilots and post-implementation metrics.

11. Conclusion

Campaign B is the clearest immediate priority because it produced the highest credential submission rate. The exercise demonstrates how phishing outcomes can be translated into financial scenarios, but executive decisions should rely on validated incident frequency, realistic loss distributions and measured control effectiveness. Fund risk-reducing controls while improving telemetry so future estimates can be defended as enterprise risk measures rather than simplified classroom projections.

Prepared by: GRC Risk Analysis Team